REQUIRED CHANGES

Sterl: from an open demo to a bank you log in to

Requested by Mehak Javed, 10 November 2026. Written with Claude Code. Version 3: all extra changes adopted, security questions dropped, face approach decided.

1. Summary

Today anyone who opens sterl-bank.vercel.app sees one customer's balances, transactions and card. That is because login was planned for the end (Week 4, Day 22), so the site is still an open showcase. **The requirement:** Sterl must work the way a real bank does. Nothing personal is visible until you log in, each customer sees only their own money, a new visitor can open an account online, and logging in is strongly protected.

This is the right call, and it matches how banks are judged: on trust, not features. It also means **authentication has to move earlier in the plan**: every API endpoint built from now on needs to know *who* is asking. Building it at the end would mean rewriting every endpoint and its tests.

The data stays 100% fake (ADR-002). Some parts of the request therefore change shape so Sterl never collects real personal or biometric data. Section 3 explains each one.

2. The requested changes

Your eight changes, what each means in practice, and how it would be built.

Your request	What it means for the customer	How we build it
1. One personal dashboard, no open data	Every banking page is private. Logged out, you only see a public landing page, Log in, Open an account and Help. Logged in, the dashboard shows only your own accounts.	Next.js route guard (proxy) sends logged-out visitors to /login. The Java API checks on EVERY request that the data belongs to the logged-in customer, so hiding pages in the browser is not the only protection.
2. Highly secured login: strict passwords, facial recognition, security questions	Password plus a second factor: Face ID / Touch ID on your own device, or an authenticator-app code (see 3.2). Security questions: dropped (see 3.3).	Spring Security. Passwords hashed with Argon2id (never stored). Second factor: passkeys (Face ID / Touch ID via WebAuthn) or an authenticator-app code (TOTP). Account lock after repeated failures.
3. Dashboard with all the user's data	Balances, transactions, cards, payees, round-ups and settings, all for the logged-in customer only.	Every endpoint reads the customer from the login session. The front end is switched to the Java API (plan Day 12).
4. All transactions inside the logged-in account	Transfers and payments can only be made from your own accounts, while logged in.	The customer always comes from the session, never from the request body. Sensitive actions ask for Face ID / code again (step-up authentication). Idempotency keys stop double payments (Day 11).
5. Cards only when logged in, only if you have one	The Cards page and card details exist only inside your account.	Card endpoints scoped to the customer. Full card number hidden until re-authentication. Published test numbers only (e.g. 4242 4242 4242 4242).

Your request	What it means for the customer	How we build it
6. Account check and online account opening	Log in or Open an account. Opening asks for details, checks you're not already a customer, runs a (simulated) identity check, sets up your login and security, and issues a card.	Sign-up flow: details, duplicate check, identity check (document + selfie + liveness, through a simulated provider, see 3.2), password, second factor; then a current account (new sort code and account number) and a test card are created in one database transaction, written to the audit log.
7. Personal settings per user	Theme, accessibility, notifications, round-ups, card controls and security settings follow you to any device.	Settings move from browser storage (Zustand) to a settings table per customer in PostgreSQL, behind the API.
8. A more modern front end	A full visual refresh, done soon as its own phase.	A design-system pass (components, spacing, motion), keeping our own brand, the demo banner and accessibility.

3. What has to be adjusted, and why

These keep Sterl safe and legal while still showing everything a real bank does.

3.1 Fake data only, even when visitors sign up

The plan's launch rules say Sterl must never ask visitors for real names, card numbers, bank logins or money. An online sign-up form invites people to type real details, and storing those would make Sterl hold real personal data under UK GDPR. So the sign-up must make faking easy and real data hard:

- A clear notice on the form: **"Use made-up details. Never enter real personal information."**
- A **"Fill with fake details"** button that generates a complete fake identity (Faker).
- Email must end in **@example.com** (a domain reserved so it can never reach a real inbox). Sterl never sends real emails or texts.
- No real ID documents, selfies or phone numbers. The identity check is simulated.
- Self-created accounts are **deleted automatically after 7 days**.

3.2 Faces: how real banks use them, and how Sterl will

Face data is *biometric data*, a special category under UK GDPR: a bank may only process it with a legal basis, a data protection impact assessment and strict security. Real banks use faces in two separate places, and in neither does the bank keep a face to log you in:

- **Logging in: passkeys (WebAuthn).** Your own phone or laptop checks your face or fingerprint (Face ID, Touch ID, Windows Hello). The bank only receives a cryptographic signature proving the check passed; the face never leaves the device. Passkeys also can't be phished: they only work on the bank's real web address. **Sterl builds this for real**, with the same standard banks use.
- **Opening an account: identity verification.** You photograph an ID document and take a selfie with a liveness check (blink, turn your head). This is done by a specialist identity-verification provider; the bank receives the result (pass, refer or fail, with reasons) and keeps that as evidence. **Sterl builds the same integration**: an *IdentityVerificationProvider* interface in Java, with a *simulated provider* that runs the full flow (document step, selfie step, liveness step, decision) on built-in **sample test images**, never a real camera picture. Swapping in a real provider's sandbox later only means a new class.

Why not store real faces to look more real? A bank interviewer would see it the other way round: collecting visitors' biometrics in a portfolio app, with no legal basis, is exactly the risk their compliance teams exist to stop. What makes Sterl read as production work is that it uses the real standards (passkeys, a provider-style ID check with pass/refer/fail outcomes, an audit trail) and that you can explain *why* the bank never holds the face. Sterl stays

clearly labelled as a portfolio demo with fake data; describe it that way on your CV and in interviews.

3.3 Security questions: dropped

Decided by Mehak on 10 November 2026: no security questions. They are also discouraged by current identity guidance (NIST SP 800-63B), because answers are often public or guessable. Account recovery will use the second factor (passkey or authenticator app) instead.

3.4 Strict passwords: length beats complexity

Modern guidance (NIST, the UK's NCSC) prefers long passwords checked against lists of common and breached passwords over rules like "one capital, one symbol" and forced changes, which push people to weak, predictable passwords. Sterl's rules:

- At least 12 characters (up to 128); spaces allowed, so passphrases work.
- Rejected if it's a common or known-breached password, or contains your name or email.
- A strength meter while typing; passwords stored only as Argon2id hashes.
- 5 wrong attempts lock the account for 15 minutes; the customer is told.

3.5 Recruiters must still see Sterl in seconds

A recruiter won't fill in a sign-up form. The landing page gets a **"Try the demo"** button that logs straight into a ready-made fake customer (with a pretend second-factor step), so reviewers see the whole bank in one click. Proper sign-up stays available for anyone who wants to test it.

4. Extra changes (all 17 adopted)

Additions a bank would expect. Mehak adopted all of them on 10 November 2026; the last column says when each is built.

Area	Change	When
Security	Automatic logout after 5 minutes without activity, with a warning at 4 minutes	Auth sprint B
Security	Step-up authentication (Face ID / code again) for: new payee, large transfer, showing card details, changing password or security settings	Auth sprint B
Security	"Security activity" page: your logins, devices and sensitive actions (your slice of the audit log)	Days 12-14
Security	In-app alert when someone logs in from a new device; "Sign out of all devices" button	Auth sprint B
Security	Secure sessions: HttpOnly, Secure, SameSite cookies; CSRF protection; security headers (CSP, HSTS); rate limiting	Auth sprint A
Security	Tests proving customer A can never read customer B's data by guessing an id (OWASP API Security risk no. 1)	Auth sprint A
Roles	Credit Risk desk becomes a staff area (risk officer role); customers never see it. An admin role can unlock accounts and read the audit log	Week 3
Roles	FX desk becomes a staff area for traders	Week 3
Customer	Card controls: freeze, online payments on/off, spending limit, replace a lost card (new test number)	Days 12-14
Customer	Payees: add with the simulated name check, remove, see recent payments to each	Days 12-14
Customer	Notifications centre (payments in and out, security alerts)	Days 12-14

Area	Change	When
Customer	Download statements (CSV, then PDF)	Week 3
Privacy	"Download my data" and "Close my account" (UK GDPR rights), and a privacy notice page	Week 4
Customer	A short welcome checklist after opening an account (set up passkey, add payee, set round-ups)	Auth sprint B
Engineering	ADR-005: authentication design; a short threat model in docs/	Auth sprint A
Engineering	Several seeded fake customers (e.g. 5), so data isolation can be tested and demoed	Auth sprint A
Accessibility	Login and sign-up fully usable by keyboard and screen reader, including the passkey step	Auth sprints A-B

5. Where this fits in the plan

Recommendation: keep Day 11 (safe transfers), then build authentication straight away, before any more customer endpoints. Login was planned for Day 22; that slot is freed up.

When	What
Day 11 (as planned)	Safe transfers with idempotency keys. The API takes the customer from a single "current customer" placeholder, so it plugs into login later with no rewrite.
Auth sprint A (about 3 days)	Flyway V3: users, credentials, sessions; 5 fake customers. Spring Security password login (Argon2id), secure sessions, CSRF, security headers, rate limiting. Every endpoint scoped to the logged-in customer, with isolation tests. Next.js login page, route guard, public landing page, "Try the demo" button. ADR-005 and threat model.
Auth sprint B (about 4 days)	Online account opening with fake-data safeguards, simulated identity verification (document, selfie, liveness on sample images) and card issuing. Second factor: passkeys (Face ID / Touch ID) and authenticator app. Account lockout, inactivity logout, step-up authentication, new-device alert, sign out everywhere, welcome checklist.
Plan Days 12-14 (about 4 days)	Send money with the payee name check, payees management, card controls, round-ups through the API, per-user settings, notifications centre, security activity page, audit log; review and release v0.2.
Week 3	Credit Risk desk and FX desk as staff areas (risk officer, trader and admin roles), statement downloads, as planned otherwise.
Week 4	"Download my data", "Close my account" and privacy notice, alongside the planned security pass and launch.
Front-end refresh	Its own phase once the banking flows work (after Week 3, or straight after launch).

Time impact: about 9 extra days with all 17 extras. Moving login out of Day 22 and the Ask Sterl assistant to after launch (the plan already allows this) brings the launch to roughly 5 days later than planned. If time runs short, drop to the plan's own priority order: Java API and SQL, then the Credit Risk desk, then CI and tests, then deploy.

6. Decisions

Decided

Decision	Answer
Adopt all 17 extra changes?	Yes (10 Nov 2026)
Security questions?	Dropped (10 Nov 2026)
Faces?	Passkeys (Face ID / Touch ID) for login; simulated identity verification (document, selfie, liveness on sample images) for account opening; real faces never stored (10 Nov 2026)

Still open

Decision	Recommended answer
Move authentication earlier, right after Day 11?	Yes
Sign-up emails restricted to @example.com?	Yes (guarantees no real inboxes)
Delete self-created accounts after how long?	7 days
Keep the open demo until login ships, or take the dashboard down now?	Keep it, with "Try the demo" arriving in Auth sprint A

Every change follows the existing rules: integer pence, fake data only, the demo banner on every page, our own brand, tests with every feature, and one branch and pull request per story.